

SCORE

Smart Cost-Optimized Recognition & Evaluation Engine

Lernende, kostenoptimale Belegerkennung für die Finanzbuchhaltung

Auftraggeber	Hoffmann & Partner Steuerberatung, Dr. Marion Hoffmann
Autor	Frank Arendt
Datum	8. Oktober 2026 (überarbeitete Fassung; erste Fassung vom 30. September 2026)
Weiterbildung	Digitalisierungsmanager/in mit KI, Skill Sprinters

Inhalt

1. Executive Summary
2. Unternehmensanalyse und Problemraum
3. Konzeption und Architektur
4. Umsetzung
5. Ergebnisse
6. Change Management
7. Datenschutz und Sicherheit
8. Fazit und Empfehlung

SCORE – Beratungs- und Systemdokumentation

Hoffmann & Partner Steuerberatung · Frank Arendt · Stand 8. Oktober 2026

Plattform	n8n 2.35.1 (Workflows und Code-Nodes, drei externe Task-Runner), DuckDB (SQL-APIs auf Port 5001 und 5005), Tesseract, Ollama (glm-ocr), Claude-Modelle über Gateway, OpenRouter und direkt, LightGBM-Dienst (Docker-Container), Docling (Port 8015), Redis mit webdis (Klärfall-Cache), EU-VIES (USt-IdNr.-Prüfung)
Status	Seit dem 8. Oktober 2026 läuft die Belegart-Architektur im Live-Hauptprozess: Eine regelbasierte Klassifikation (49 Belegarten) bestimmt die zu erfassenden Felder; der Request-Parameter <code>plichtfelder</code> entfällt. Rechenprüfung (R01–R32) im Shadow-Modus, USt-IdNr.-Prüfung mit PDF-Protokoll, Startstufe per LightGBM mit Priorität (<code>prioritaet</code>), Bildkorrektur abgeschaltet. Sicherheitsprüfung im Shadow-Modus (beobachtet, blockiert noch nicht); SQL-Treffer erzwingen den Klärfall in jedem Modus. kNN läuft als Vergleichsverfahren.
Zugehörige Dokumente	Projektantrag SCORE (Abschnitt 4.6), Anforderungsdokument v1.6 (Abschnitte 4 und 5), Gesamtbericht „Massentest 1000 Belege und rechnerische Validierung“ (08.10.2026), Performance-Bericht Massentest (08.10.2026), Testbericht GIF-Massentest und Startstufen-Vergleich, Maßnahmenpapier Prompt Injection, Testprotokoll Prompt-Injection-Schutz, Bericht „kNN vs. Fuzzy Vergleich“ vom 28.09.2026, Architekturdokumentation <code>architektur-uml.md</code> (Stand 08.10.2026), Übersichtsseite <code>SCORE_Uebersicht.html</code> , Präsentation SCORE, Handout „KI-Agenten sicher einsetzen“ (SIBB e. V., 28.09.2026)

Was sich gegenüber der Fassung vom 30. September geändert hat:

- Belegart-Architektur statt fester Pflichtfelder; Zusatzfelder (IBAN, Netto, USt-Betrag, Brutto), Rechenprüfung und USt-IdNr.-Prüfung sind neu (Abschnitte 4.2, 4.6, 4.7).
- Der Massentest mit 1000 Belegen vom 7./8. Oktober ersetzt die bisherigen Testreihen als Hauptnachweis (Abschnitt 5.2). Er zeigt auch Schwächen, die in der ersten Fassung nicht sichtbar waren: Die Feldrichtigkeit gegen die Ground Truth liegt auf den Testkassenbons deutlich unter der Füllquote, und das Verhalten der Sicherheitsprüfung auf realen Belegen verlangt eine Kalibrierung vor dem Umschalten auf Enforce.
- Die Antwortzeit-Kennzahlen sind auf Durchsatz umgestellt und mit den neuen Messwerten belegt (Abschnitt 5.3).
- Der Ausschluss von `quality`- und Verdachtsfällen aus dem Trainingspool ist umgesetzt (seit 30.09.); die alte Eskalationsleiter ist gelöscht.

1. Executive Summary

Hoffmann & Partner Steuerberatung verarbeitet rund 30.000 Belege im Monat. 20 bis 30 % davon werden als Klärfall von Hand bearbeitet; das bindet 2,5 Vollzeitkräfte und kostet zusammen mit dem IDP-/OCR-Dienst (typisch 0,30 € je Beleg) rund 267.800 € im Jahr.

SCORE ersetzt die starre Erkennung durch einen lernenden Prozess: Ein Modell wählt für jeden Beleg das günstigste Verfahren, das voraussichtlich reicht, von kostenfreier lokaler OCR bis zum Cloud-Modell. Eine regelbasierte Klassifikation ordnet den Beleg einer von 49 Belegarten zu und legt fest, welche Felder erfasst werden; eine rechnerische Prüfung und, wo vorgesehen, eine USt-IdNr.-Prüfung sichern das Ergebnis ab. Unsichere Ergebnisse gehen in eine Klärfall-Prüfung statt ungeprüft weiter.

93,4 %

ohne Klärfall
(Massentest, 1000 Belege)

0,107 Cent

Erkennungskosten
je Beleg (1,07 € je 1000)

170–190

Belege je Stunde
(gemessen, 3 Worker)

18 von 18

Angriffe erkannt,
0 von 6 Fehlalarmen

Im Massentest mit 1000 Belegen (600 Kassenbons als GIF, 400 deutsche PDFs) blieben 93,4 % ohne Klärfall, bei Kosten von 1,07 € für alle 1000 Belege; kein Beleg endete ohne Ergebnis. **Wichtige Einschränkung:** „ohne Klärfall“ heißt, dass alle Pflichtfelder gefüllt sind, nicht dass sie stimmen. Gegen die Ground Truth der Kassenbons lag die Feldrichtigkeit je Feld zwischen 41 % (Netto) und 71 % (Verkäufer); die Testbons (Singapur, englisch) sind für eine deutsche Kanzlei nicht repräsentativ. Die Dunkelverarbeitung echter Mandantenbelege ist deshalb erst im Pilot belastbar zu messen. Ein Schutz gegen manipulierte Belege erkannte im Beobachtungsmodus 18 von 18 Angriffen ohne Fehlalarm; er blockiert noch nicht, und auf realen Belegen markiert er im Shadow-Modus viele Belege (Abschnitt 5.2).

Hochgerechnet sinken die Kosten auf rund 40.500 € im Jahr, ein Einsparpotenzial von rund 227.300 €. Die Rechnung nimmt eine Dunkelverarbeitung von 87 % an. Die Investition von 20.000 bis 50.000 € amortisiert sich in ein bis drei Monaten, vor Betriebs- und Wartungskosten.

Empfehlung: vierwöchiger Pilot mit einer Mandantengruppe parallel zum bisherigen Dienst, mit manuell geprüfter Stichprobe zur Messung der echten Feldrichtigkeit; danach schrittweise Ablösung.

2. Unternehmensanalyse und Problemraum

2.1 Firmenkontext

Hoffmann & Partner Steuerberatung ist eine mittelgroße Kanzlei mit mehreren Berufsträgern und einem Mandantenstamm aus kleinen und mittleren Unternehmen sowie Freiberuflern. Die laufende Finanzbuchhaltung und darin die Erfassung eingehender Belege (Rechnungen, Quittungen, Kassenbons) für die DATEV-Buchführung bindet einen erheblichen, wiederkehrenden Teil der Kapazität, stiftet für die Mandanten aber kaum beraterrelevanten Mehrwert.

Auftraggeber: Hoffmann & Partner Steuerberatung (Auftraggeberin Dr. Marion Hoffmann). Der Belegkatalog der Finanzbuchhaltung umfasst 49 Belegarten (in der ersten Fassung waren es mindestens 17 Belegtypen). Bei 200 bis 400 FiBu-Mandaten mit 70 bis 120 Belegen je Mandat fallen rund 30.000 Belege im Monat an; alle Berechnungen dieser Dokumentation beruhen auf diesem Volumen.

2.2 Berufsrolle und Wertschöpfungslogik

Die Wertschöpfung einer Steuerkanzlei entsteht nicht in der Erfassungsroutine, sondern in Beratung, Bewertung, steuerlicher Gestaltung und im Vertrauensverhältnis zum Mandanten. Standardisierbare Aufgaben wie Belegerfassung, Deklaration und Reporting werden zunehmend KI-gestützt automatisiert; dort entsteht kein Wettbewerbsvorteil mehr durch Arbeitskraft, sondern durch die Frage, wer diese Automatisierung am kosteneffizientesten und zuverlässigsten betreibt.

Für Hoffmann & Partner heißt das: Jede Stunde, die nicht mehr in die manuelle Übertragung von Beleginhalten fließt, steht für Beratung zur Verfügung, die Tätigkeit, an der die Kanzlei verdient. SCORE ist damit kein reines IT-Projekt, sondern eine Verschiebung von Wertschöpfung weg von Erfassung hin zu Beratung.

Fachkräftemangel: Hinzu kommt der zunehmende Fachkräftemangel in der Steuerberatung. Qualifizierte Steuerfachangestellte sind schwer zu finden und zu halten, und gerade die Erfassungsarbeit gilt als unattraktiv: monoton, fehleranfällig und ohne Bezug zur eigentlichen Beratung. Kanzleien, die ihre knappen Fachkräfte in dieser Routine binden, verlieren an Attraktivität als Arbeitgeber und riskieren, dass Stellen

unbesetzt bleiben. SCORE nimmt die unattraktive Erfassung ab und verlagert die Arbeit der Fachkräfte auf Prüfung, Klärung und Beratung. Das entlastet das Team, macht die Tätigkeit anspruchsvoller und hilft, vorhandene Fachkräfte zu halten und neue zu gewinnen.

2.3 Betroffener Geschäftsprozess und Schmerz in Zahlen

Belege erreichen die Kanzlei auf unterschiedlichen Wegen (Papier, Scan, E-Mail-Anhang, Foto) und in heterogener Qualität. Ein IDP-/OCR-Dienst liest sie aus; was er nicht sicher erkennt, prüft eine Fachkraft, ordnet es zu und überträgt die Werte von Hand in DATEV.

Schmerz in Zahlen (Standard einer mittelgroßen Kanzlei): 70 bis 80 % der Belege laufen bereits dunkel (Branchenspanne 60 bis 80 %). Die übrigen 20 bis 30 %, also 6.000 bis 9.000 Belege im Monat, werden als Klärfall bearbeitet, mit 2 bis 3 Minuten je Beleg. Das sind 200 bis 450 Arbeitsstunden im Monat; die Kanzlei setzt dafür 2,5 Vollzeitkräfte ein (rund 345 produktive Stunden im Monat). Hinzu kommen IDP-/OCR-Kosten von 0,10 bis 0,50 € je Beleg, typisch 0,30 €.

Problem: Belege unterscheiden sich stark in Layout, Inhalt und Bildqualität; eine einzige Erkennungsmethode passt nicht für alle. Einfache Belege sind mit lokalen, kostenfreien Modulen lösbar, schwierige brauchen teure Cloud-LLMs. Es fehlt eine automatische, kostenoptimale Verfahrenswahl je Beleg; die Erfahrung aus abgeschlossenen Fällen wird nicht genutzt. Zugleich ändern sich Vision-Modelle laufend in OCR-Qualität und Preis. Dazu kommt, dass je nach Belegart andere Felder und andere Prüfungen nötig sind (ein Kontoauszug braucht keine Rechnungsnummer, eine Rechnung mit ausländischer USt-IdNr. braucht deren Prüfung).

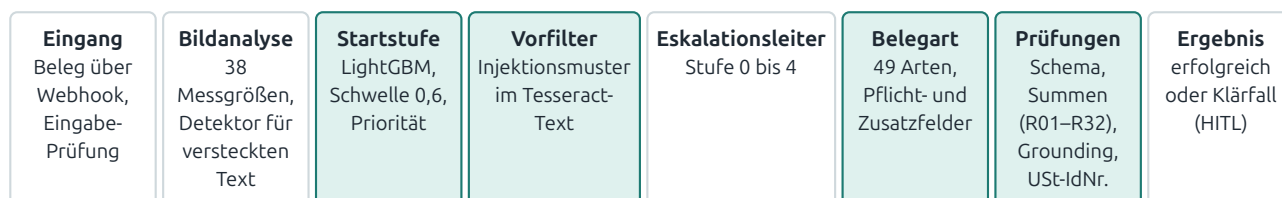
2.4 Ziel

Jeder Beleg wird mit dem günstigsten Verfahren erkannt, das voraussichtlich reicht; unsichere Ergebnisse gehen in eine Klärfall-Prüfung statt ungeprüft weiter. Das System lernt aus jedem abgeschlossenen Fall.

3. Konzeption und Architektur

3.1 Architektur im Überblick

SCORE erkennt Belege über eine Eskalationsleiter aus fünf Modulen mit steigenden Kosten. Für jeden Beleg wird ein Startmodul vorgeschlagen; scheitert es, steigt die Leiter zur nächsten Stufe auf. Daneben verarbeitet Docling geeignete Belege kostenfrei und ohne LLM an der Leiter vorbei. Die zentralen Komponenten greifen an vier Stellen in diesen Ablauf ein: bei der Wahl des Startmoduls, vor dem ersten LLM-Aufruf, bei der Festlegung der Felder und nach der Extraktion.



Grün hinterlegt: lernende Startstufe, Sicherheitsprüfung, Belegart-Klassifikation und Rechen-/USt-IdNr.-Prüfung. Die Reihenfolge von Belegart und Eskalationsleiter ist vereinfacht dargestellt: Die Belegart wird aus dem Text bestimmt, den Tesseract oder Docling liefert; die Felder, die erfasst werden müssen, ergeben sich daraus.

3.2 Prozessmodell Ist (BPMN)

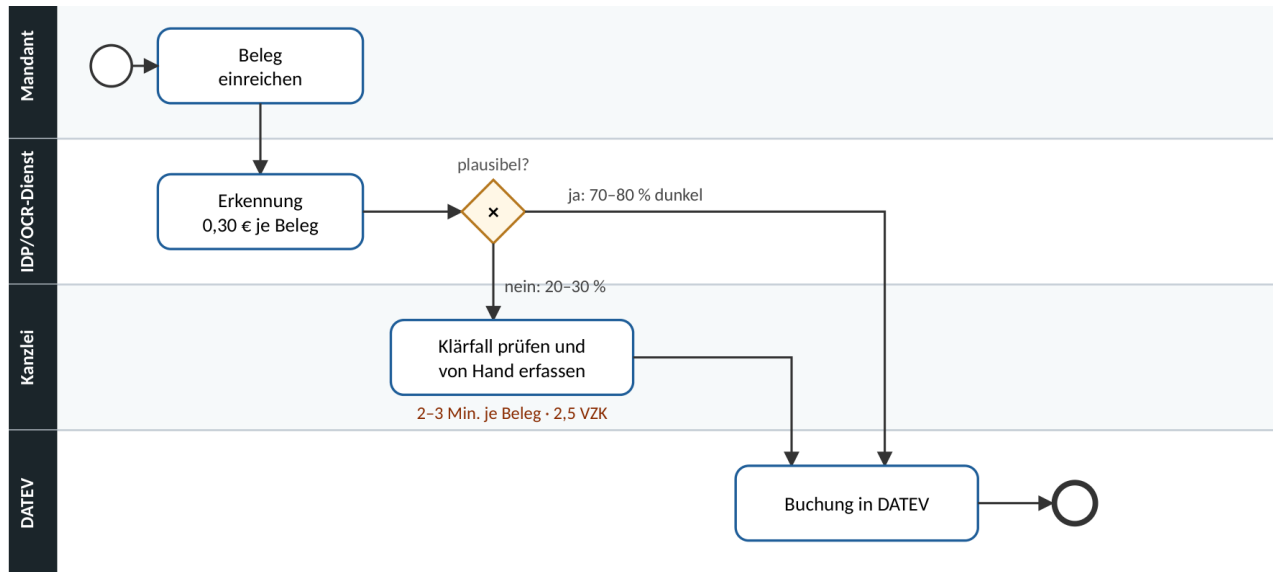


Abb. 1: Ist-Prozess der Belegverarbeitung mit IDP-/OCR-Dienst und manueller Klärung

3.3 Prozessmodell Soll mit SCORE (BPMN)

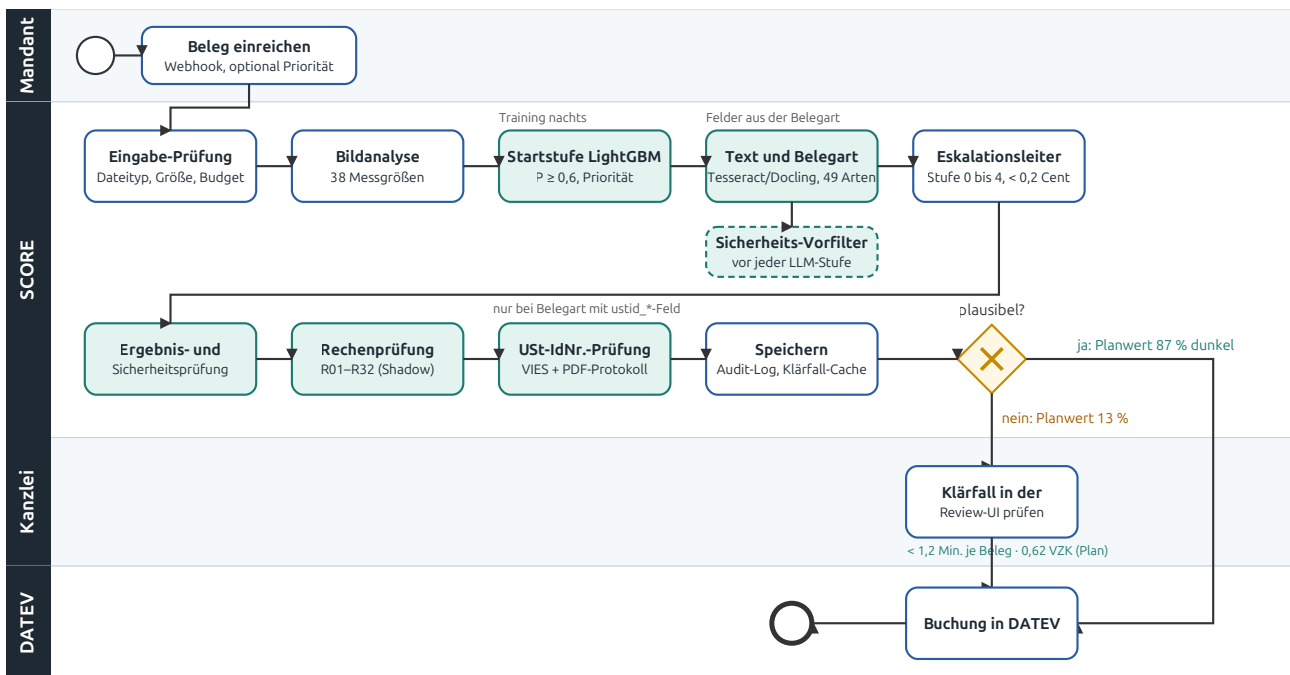


Abb. 2: Soll-Prozess mit Belegart-Klassifikation, lernender Startstufe, Eskalationsleiter, Rechen- und UST-IdNr.-Prüfung und Klärfall-Prüfung in der Review-UI (Stand 08.10.2026). Grün: lernende oder regelbasierte Prüfkompontenten; gestrichelt: Sicherheits-Vorfilter vor jeder LLM-Stufe. Die Rechenprüfung läuft im Shadow-Modus und entscheidet noch nicht über „plausibel“. „87 % dunkel“ und „0,62 VZK“ sind die Planwerte der Wirtschaftlichkeitsrechnung (Abschnitt 5.3), nicht Messwerte.

3.4 Tool-Wahl und Begründung

Komponente	Wahl	Begründung
Orchestrierung	n8n	visuelle, nachvollziehbare Workflows statt Skript; Submodule wiederverwendbar; selbst betrieben, damit Belege im Haus bleiben
Wissensbasis	DuckDB	schnelle Analysen auf tausenden Fällen ohne Datenbankserver; für Lastverteilung ist später PostgreSQL vorgesehen

Startstufe	LightGBM	lernt aus tabellarischen Messgrößen in Sekunden, nachts neu trainierbar; im Vergleich besser als kNN (77,1 % gegenüber 62,7 % in der Kreuzvalidierung)
Belegart und Felder	regelbasierter Klassifikator (JavaScript), Katalog <code>belegarten.json</code>	deterministisch, in Millisekunden, ohne Kosten und ohne Datenübermittlung; Regeln sind prüfbar und im Katalog gepflegt, statt jede Belegart per LLM-Aufruf bestimmen zu lassen
Rechenprüfung	Regelkatalog R01–R32, Rechnung in Cent	Rechenfehler auf Belegen lassen sich exakt prüfen; ein LLM wäre hier teurer und weniger verlässlich
USt-IdNr.-Prüfung	EU-VIES (REST), eigener PDF-Schreiber	amtliche Bestätigung der Nummer; je Prüfvorgang ein eigenständiges, archivierbares PDF-Protokoll mit Hash-Kette
Lokale Erkennung	Tesseract, Docling, Ollama (glm-ocr)	kostenfrei und lokal, keine Übermittlung an Dritte; deckt einfache Belege ab
Cloud-Eskalation	Claude Haiku (Gateway, OpenRouter, direkt)	nur für Belege, die lokal nicht sicher erkannt werden; günstiges Modell mit guter Feld-Erkennung
Klärfall-Cache	Redis mit webdis	temporäre Ablage mit Aufbewahrungsfrist für die Review-UI
Laufzeit	Docker, Produktion auf Mac Studio M5 Ultra	ein Container je Komponente; lokale Vision-Modelle nativ mit Apple-GPU (Entwicklung und Tests liefen auf einem CPU-Rechner, siehe Abschnitt 5.3)

Gegenüber kommerziellen IDP-Diensten mit 0,10 bis 0,50 € je Beleg senkt die Kombination aus lokalen Verfahren und gezielter Cloud-Eskalation die Erkennungskosten auf rund 1 % (gemessen 0,107 Cent je Beleg). Einfache Belege bleiben vollständig in der Kanzlei; schwierige gehen heute noch an ein Cloud-Modell, im Massentest die Mehrzahl (Abschnitt 7.4). Mit leistungsstarker lokaler Hardware und großen Open-Weight-Modellen soll ein Proof of Concept zeigen, ob sich die Cloud-Stufen ganz ersetzen lassen.

4. Umsetzung

4.1 Eskalationsleiter und Stufen

Kostenstufe	Modul	Betrieb
0	tesseract	lokal
1	glm-ocr:latest	lokal (Ollama)
2	claude-haiku	Skill-Sprinters-Gateway
3	openrouter/anthropic/claude-3-haiku	OpenRouter
4	claude-haiku-4-5-20251001-direct	Anthropic direkt
–	docling	lokal, ohne LLM, kostenfrei; separater Pfad außerhalb der Leiter

Die Leiter besteht aus einem Orchestrator, der die Stufen nach einer Registry der Reihe nach aufruft und vor jeder Stufe die Budget-Prüfung befragt, und aus je einem Workflow pro Stufe mit gleichem Vertrag. Die frühere Sammel-Leiter in einem Workflow ist seit dem 8. Oktober gelöscht.

Belege in Dokument- und gängigen Bildformaten (PDF, PNG, JPEG, TIFF, BMP) können ohne LLM über einen Docling-Bypass verarbeitet werden. Dieser Pfad ist keine Stufe der Leiter und wird in den Startstufen-Auswertungen separat geführt.

Begriffe: Overshoot heißt, die vorgeschlagene Startstufe liegt über der tatsächlich erfolgreichen; eine funktionierende günstigere Stufe wird übersprungen, das kostet Geld. Undershoot heißt, der Vorschlag

liegt unter der tatsächlich erfolgreichen Stufe; das ist unkritisch, weil die Leiter weiter aufsteigt, und kostet nur Laufzeit.

4.2 Belegart-Klassifikation und Felder

Früher gab der Aufrufer die Pflichtfelder mit; heute leitet SCORE sie selbst ab. Ein regelbasierter Klassifikator (JavaScript, erzeugt aus `belegklassifikation.template.js` und dem Katalog `belegarten.json`) bestimmt aus dem OCR- oder Docling-Text eine von 49 Belegarten (etwa Kleinbetragsrechnung, Standardrechnung, Bewirtungsbeleg, Kassenbeleg, Fahrausweis, Kontoauszug, Import, innergemeinschaftlicher Erwerb, Rechnungskorrektur). Aus der Belegart folgen die Pflichtfelder (Rechnungsnummer, Datum, Verkäufer, Kunde, soweit die Belegart sie kennt) und die Zusatzfelder IBAN, Netto, USt-Betrag und Brutto; bei der Belegart „plausibel“ gibt es keine Zusatzfelder. Fehlt ein Merkmal, greift die Belegart UNBEKANNT mit den Standardfeldern.

Klassifikator v2 (live seit 8. Oktober): Länderkennzeichen werden gegen eine Whitelist geprüft, Beträge auch aus der Zeile unter dem Label gelesen (sonst der größte Betrag ohne Datum und Uhrzeit), Storno- und OSS-Marker sind enger gefasst, und Wörter wie „TOTAL“ lösen keine Import-Zuordnung mehr aus. Auf 118 Belegen des Massentests sank der Anteil UNBEKANNT von 58 % auf 31 %, und falsche Zuordnungen zu Import oder Erwerb gingen von 20 auf 0 zurück (Auswertung offline, ohne Ground Truth für die Belegart). Der Massentest selbst lief noch mit der Vorversion (UNBEKANNT 46,9 %).

Grenze: Für die Belegart gibt es keine Ground Truth; die Verteilung ist eine Auswertung, keine gemessene Trefferquote. Die Klassifikation wirkt nur so gut wie der erkannte Text; bei schlechter OCR bleibt ein großer Anteil bei UNBEKANNT.

4.3 Startstufe per LightGBM (produktiv)

Die Startstufe der Eskalationsleiter kommt von vier LightGBM-Modellen, je eines pro Stufe. Jedes schätzt aus den 38 normierten Messgrößen eines Belegs die Wahrscheinlichkeit, dass diese Stufe für den Beleg reicht („P Stufe reicht“). Gewählt wird die billigste Stufe mit einer Wahrscheinlichkeit von mindestens 0,6. Scheitert sie, steigt die Leiter wie gewohnt weiter auf. Der Dienst wird über `POST /startstufe/vorhersagen` aufgerufen; fällt er aus, startet der Beleg bei Tesseract.

Komponente	Aufgabe
SCORE – Startstufe LightGBM (Submodul, <code>ScoreStartstufe001</code>)	Vorhersage der Startstufe im Hauptprozess, Anwendung der Schwelle; Fallback auf Tesseract bei Ausfall des Dienstes
SCORE – Startstufe Training (FA-11, <code>ScoreStartstufeTr01</code>)	Nächtliches Training um 02:30 Uhr mit den erfolgreichen Fällen ohne Docling-Fälle; unter 100 Fällen wird nicht trainiert. Die Modelle liegen im Docker-Volume des LightGBM-Containers. Neue Fälle fließen automatisch ein. Per Klärfall korrigierte Fälle gehen nicht in den Trainingspool (Begründung in Abschnitt 4.9); <code>quality</code> -Fälle und Fälle mit Sicherheitsverdacht sind seit dem 30. September ausgeschlossen.

Priorität (neu): Der Request-Parameter `prioritaet` steuert, wie stark Kosten oder Laufzeit zählen. `kosten` (Standard) startet bei der billigsten Stufe mit $P \geq 0,6$. `zeit` überspringt die kostenlosen lokalen Stufen und beginnt bei der ersten kostenpflichtigen Stufe, weil das lokale Ollama auf der Test-CPU im Mittel 67 s je Aufruf braucht, Claude Haiku dagegen 1,5 s (Abschnitt 5.3). `ausgewogen` liegt dazwischen. Die Auswahl der Module wurde per Unit-Test geprüft; im Live-Test wählte die Startstufe bei allen 14 Testbelegen ohnehin Haiku, sodass der Pfad „Ollama gewählt, aber übersprungen“ live nicht beobachtet wurde.

Kreuzvalidierung (5-fach, ohne Docling-Fälle): LightGBM trifft die richtige Startstufe in 77,1 % der Fälle, kNN in 62,7 %. GIF-Massentest vom 30.09. (83 auswertbare Belege): LightGBM mit Schwelle 0,6 trifft die richtige Startstufe in 88,0 % der Fälle (zu billig 9,6 %, zu teuer 2,4 %). kNN mit Regel majority und $k = 9$ erreicht 77,1

%; dass dieser Wert mit dem der LightGBM-Kreuzvalidierung übereinstimmt, ist Zufall, es sind verschiedene Datengrundlagen. Höhere LightGBM-Schwellen (0,8 / 0,9) erreichen nur 78,3 / 72,3 % bei deutlich mehr zu teuren Starts. Die Regel „immer Stufe 2“ liegt auf diesen Belegen mit 90,4 % gleichauf, weil fast alle Belege Stufe 2 brauchen; der Nutzen des Lernens ist erst auf Mischungen mit vielen Stufe-0/1-Belegen nachzuweisen (34 % im Trainingspool). Auch im Massentest vom 8. Oktober endeten 84,4 % der Belege bei Claude Haiku (Gateway); der Beleg-Mix (GIF-Kassenbons) begünstigt weiterhin eine einfache Regel.

Zusammenspiel mit den Strategien: Nur die Strategie `cost` nutzt das Modell.

	<code>cost</code>	<code>quality</code>
Startstufe	vorhergesagt von LightGBM (Schwelle 0,6)	immer die beste Stufe laut Rang <code>qualitaet</code> der Registry
Rolle des Modells	entscheidet über den Start	keine
Aufruf nötig	ja	nein, sollte übersprungen werden

Für `quality` ist das Modell auch nicht sinnvoll nutzbar: Seine Trainingsdaten stammen aus dem Modus `cost`, das Label ist die erste erfolgreiche Stufe. Höhere Stufen wurden bei diesen Fällen nie ausprobiert. Das Modell schätzt deshalb, welche Stufe die günstigste ist, die reicht, und nicht, mit welcher Wahrscheinlichkeit eine bestimmte Stufe den Beleg schafft. Für eine qualitätsorientierte Auswahl bräuchte es ein eigenes Modell mit Daten, bei denen mehrere Stufen auf denselben Beleg angewendet wurden; solche Daten fallen bei `quality` an.

Trennung beim Training: `quality`-Fälle starten immer auf der besten Stufe; ihr `verwendetes_modul` ist daher fast immer eine teure Stufe, auch wenn eine günstigere gereicht hätte. Gelangen sie ins Training, lernt das Modell, dass ähnliche Belege teure Stufen brauchen, und die Quote zu teurer Starts im Modus `cost` steigt unbemerkt. Deshalb schließt die View `v_erfolgreiche_faelle` (Quelle des Trainings, des kNN-Pools und von `fuzzy_match`) seit dem 30. September `quality`-Fälle und Fälle mit `flag_verdacht` aus.

Offen – Testdaten im Trainingspool: Die rund 1000 Fälle des Massentests (überwiegend englische Singapur-Kassenbons) liegen in `score_db` und fließen beim nächsten nächtlichen Training in das Modell ein, solange sie nicht entfernt oder gekennzeichnet werden. Das kann die Startstufen-Vorhersage in Richtung dieser Belegmischung verschieben. Vor dem Pilot ist zu entscheiden, ob sie gelöscht, markiert oder bewusst im Pool belassen werden.

4.4 Vergleichsverfahren kNN

Bis zur Einführung von LightGBM war ein k-Nearest-Neighbor-Verfahren produktiv; heute läuft es als Vergleich. Für einen neuen Beleg berechnet es die quadrierte euklidische Distanz $d^2 = \sum (m_{\text{hist},i} - m_{\text{akt},i})^2$ seiner 38 normierten Messgrößen (View `score.v_erfolgreiche_faelle`, Feld `messgroessen_json`) zu allen erfolgreichen Altfällen. Alle Messgrößen gehen gleich gewichtet ein; die Normierung auf 0 bis 1 bestimmt ihren Einfluss. Aus den k nächsten Fällen wird das Startmodul abgeleitet: nach Regel `min_tier` (ursprünglicher Standard) das günstigste Modul unter den Nachbarn, nach Regel `majority` das häufigste. Kleines k reagiert fein auf die Bildqualität, großes k ist stabiler, bezieht aber weniger ähnliche Fälle ein. Liegen weniger als k Altfälle vor, werden alle vorhandenen genutzt (`k_effektiv`); ohne Altfall greift der Kaltstart-Fallback. Heute läuft kNN mit `majority`, $k = 9$ und uniformer Distanz.

Umgesetzt ist das Verfahren als Submodul „SCORE – kNN Modulvorschlag“ (n8n-ID `0nomeygcke7iE14u`, Aufruf über `executeWorkflowTrigger`, ohne eigenen Datenbankzugriff) mit zwei manuell gestarteten Prüf-Workflows: „kNN Training und Validierung (FA-11)“ (stratifizierte 80/20-Aufteilung mit festem Seed, Sweep über $k = 1, 3, 5, 7, 9$ und beide Regeln) und „kNN vs. Fuzzy Vergleich (FA-11)“ (Leave-one-out gegen die frühere Einzelnachbar-Suche). Beide versenden einen HTML-Bericht per E-Mail.

Ergebnis gegen die Einzelnachbar-Suche (Bericht vom 28.09.2026, 823 Fälle, noch mit gewichteter Distanz, $k = 5$ und `min_tier`): Overshoot 1,2 % statt 10,9 %, Exact-Match 40,6 % statt 75,7 %. kNN startet bewusst eher zu günstig; in 457 abweichenden Fällen schlug es ein günstigeres, in keinem ein teureres Modul vor. Gegen LightGBM unterliegt kNN in Kreuzvalidierung und GIF-Massentest (Abschnitt 4.3).

4.5 Strategie quality

Neben `cost` ist die Strategie `quality` umgesetzt. Sie startet auf der besten Stufe (Rang `qualitaet` in der Stufen-Registry), wertet den Tesseract-Vorlauf nicht als Ergebnis und verlangt zwei Ergebnisse, die je Pflichtfeld übereinstimmen (Vergleich normalisiert, Datum als `yyyymmdd`). Bei Abweichung entscheidet eine dritte Stufe per Mehrheit; ohne Mehrheit oder bei erschöpftem Budget geht der Fall in die manuelle Nachbearbeitung. `max_kosten` gilt strikt. Die Kosten liegen etwa beim Doppelten (Test: 0,0031 € statt 0,0016 € je Beleg). Offen: Rangfolge dynamisch statt fest, Zweitbestätigung durch eine andere Modellfamilie, LightGBM-Aufruf bei `quality` überspringen (Kapitel 8). Der `quality`-Ausschluss aus dem Trainingspool ist umgesetzt (Abschnitt 4.3).

4.6 Rechenprüfung (neu)

Die Rechenprüfung erkennt Rechenfehler auf Belegen, ohne sie zu korrigieren oder zu ergänzen: Zeilenbeträge (Menge $\times$ Einzelpreis), Summen, Rabatte, Nebenkosten, Umsatzsteuer je Steuersatz, Brutto, Skonto, Anzahlungen und Korrekturen sowie belegartspezifische Rechnungen (Kassenbericht, Lohn, Darlehen, Versicherung, Zoll und weitere). Der Prüfkatalog umfasst 32 Prüfungen (R01–R32). Jede liefert `ok`, `abweichung` oder `nicht_pruefbar` mit erwartetem und gefundenem Wert; fehlende Werte werden nie berechnet und eingetragen. Alle Beträge werden in ganzen Cent verarbeitet (kaufmännische Rundung), die Toleranz beträgt 0,02 EUR je Prüfung. Die Prüfung gibt keine steuerliche Bewertung und keine Empfehlung zum Vorsteuerabzug ab.

Seit dem 8. Oktober läuft sie im Hauptprozess im **Shadow-Modus**: Das Ergebnis steht in `daten_json.rechenpruefung` und ändert weder Status noch Antwort. Die Review-UI zeigt je Regel Zeile, erwarteten und gefundenen Wert sowie eine Erläuterung der benutzten Prüfung.

Validierung: 213 Testfälle (90 mit eingebautem Rechenfehler, 49 von 49 Belegarten abgedeckt, darunter 40 korrekte und 40 fehlerhafte Zufallsrechnungen mit festem Seed). Auf Textebene bestanden 213 von 213, mit OCR in der Produktionseinstellung 210 von 213, mit Tesseract `--psm 6` 213 von 213. Von 92 eingebauten Fehlern wurden 92 (Text), 90 (OCR Produktion) und 92 (OCR `psm 6`) erkannt; Fehlalarme: 0. Die Testbelege sind synthetisch (Monospace-Schrift, saubere Bilder); das Ergebnis belegt die Rechenlogik, nicht die Trefferquote bei beliebigen Scans.

Befund OCR: Die Standardeinstellung des Tesseract-Dienstes (kein `--psm`-Parameter, Seitenanalyse 3) trennt bei breiten Positionstabellen die Spalten; die drei Ausfälle betrafen Rechnungen mit 6 bis 8 Positionen. Mit `--psm 6` traten sie nicht auf. Empfehlung: den Dienst um einen `psm`-Parameter erweitern; das ist noch nicht umgesetzt.

Verhalten an realen Daten (Massentest): Von 1000 Belegen hatte ein großer Teil keine prüfbaren Regeln (UNBEKANNT: 4 von 469 mit geprüften Regeln). Bei Kleinbetragsrechnungen wiesen 38 von 164 (23,2 %) eine Abweichung auf, bei Import 19 von 146 (13,0 %). Häufigste Abweichung war R07 (Brutto ohne Steuerausweis, 51 Treffer), danach R02 (Summe der Positionen, 12) und R01 (Zeilenbetrag, 8). Bei Kassenbons stammen Abweichungen oft aus OCR-Lesefehlern; sie sind ein Befund zur Bewertung, kein Fehlerurteil. Deshalb bleibt die Prüfung im Shadow-Modus, bis der Pilot die Fehlalarmrate auf deutschen Belegen gezeigt hat.

4.7 USt-IdNr.-Prüfung mit PDF-Protokoll (neu)

Hat die erkannte Belegart ein Feld `ustid_*`, prüft SCORE die Nummer zusätzlich extern über den EU-Dienst VIES (REST, mit Wiederholungen bei Fehlern). Belegarten ohne USt-IdNr.-Feld lösen keine Abfrage aus. Je Prüfungsvorgang entsteht ein eigenständiges PDF-Protokoll (vom VIES-Dienst selbst wird kein PDF geliefert; SCORE erzeugt es mit einem eigenen, minimalen PDF-Schreiber), und ein Eintrag in der Tabelle `score.ustid_pruefprotokoll` hält Ergebnis und SHA-256-Hash fest. Die Einträge sind als Hash-Kette verknüpft; nachträgliche Änderungen fallen damit auf. Das Protokoll ist für die spätere Archivierung gedacht. Die Abfrage war nicht Teil des Massentests (für den Test abgeschaltet); ein Dauerbetrieb mit Last auf VIES ist ungetestet.

4.8 Weitere Submodule des Hauptprozesses

Submodul	Aufgabe
Eingabe-Prüfung (<code>4YWkqHMCKLHMFwN</code>)	Dateityp (Magic-Bytes), Base64, Größe, Kostenobergrenze, Feldnamen (Allow-List), Rate-Limit; liefert <code>feld_limits</code> (Standard 14 Zeichen je Feld) und nimmt <code>prioritaet</code> entgegen
Bildaufbereitung (<code>SiCagfDXkGs1gRA1</code>)	38 Messgrößen; die Bildkorrektur (Kontrast-Stretch, Binarisierung) ist abgeschaltet, GIF-Eingaben werden als PNG weitergegeben
Belegart-Klassifikation (<code>ScoreBelegart0001</code>)	Belegart, Pflicht- und Zusatzfelder (Klassifikator v2), Rechenprüfung R01–R32 im Shadow-Modus
USt-IdNr.-Prüfung (<code>ScoreUStIdPruef01</code>)	VIES-Abfrage nur bei Belegarten mit <code>ustid_*</code> -Feld; Hash-Kette und PDF-Protokoll
Feld-Extraktion (<code>ScoreFeldExtrakt1</code>)	Liest die Felder per Label-Heuristik aus dem OCR- oder Docling-Text. Einzige Stelle für diese Regeln (vorher dreifach kopiert); genutzt von Modul 1, dem Docling-Fallback und dem Docling-Submodul.
Docling-Extraktion (<code>ScoreDoclingExt01</code>)	Kostenfreier Pfad ohne LLM für PDF, PNG, JPEG, TIFF und BMP (<code>docling:8015/extract</code>) mit Feld-Extraktion. Umgeht Bildanalyse und Startstufe; der Text durchläuft den Sicherheits-Vorfilter. Bei Lücken folgt Tesseract, dann die Vision-Eskalation.
Budget-Prüfung (<code>ScoreBudgetPruef1</code>)	Kostenregel für den Orchestrator: die erste Stufe lokal ist immer erlaubt, kostenpflichtige Stufen nur bei <code>max_kosten > 0</code> und solange die Kosten darunter liegen. Fehlt die Antwort, gilt das Budget als nicht erlaubt (fail closed); der Fall geht in die manuelle Nachbearbeitung.
Audit-Log (<code>ScoreAuditLog0001</code>)	Eine Zeile je Anfrage in <code>score.audit_log</code> : SHA-256 der Eingabe, Format, Strategie, Status, Modul, Stufen, Kosten, Sicherheitskennzeichen und Befunde. Das Bild selbst wird nicht gespeichert; ein Schreibfehler ändert die Antwort an den Aufrufer nie.
Speichern (<code>vTUSEzj4zR2rAurD</code>)	Schreibt das Ergebnis in <code>score_db</code> , einschließlich Sicherheitsbefunden, Rechenprüfung und Startstufen-Vorhersage in <code>daten_json</code> , und baut die API-Antwort nach Kapitel 11.4 des Anforderungsdokuments.
Klärfall und Sicherheitsmeldung (<code>1rGo6aL0FFJLoMI3</code>)	Review-Fall in Redis, Review-Mail, Mail „Score security incident“ (Empfänger ist die Demo-Adresse <code>frank-demo@skillsprinters.de</code> ; nur diese Adresse ist als Absender des SMTP-Servers zugelassen)
Manuelle Nachbearbeitung (Review-UI)	Oberfläche zum Prüfen und Korrigieren von Klärfällen aus dem Redis-Fallcache (Aufbewahrung 8 Wochen), aufrufbar über <code>/webhook/score-nachbearbeitung?id=...</code> ; zeigt zusätzlich die Ergebnisse der Rechenprüfung mit Erläuterung.

Der Hauptprozess (`POST /webhook/score-hauptprozess`, n8n-ID `5qNPDgUHEA1BV9v9`) umfasst 85 Nodes, davon 19 Sticky Notes, und schreibt je Anfrage einen Audit-Eintrag. Sticky Notes folgen einheitlichen Regeln (Farbe 5, keine Überlappung mit Nodes oder untereinander, vollständig sichtbar).

4.9 Kosten und Selbstoptimierung

Nach Anforderungsdokument und Präsentation (Folien 6 bis 8) gelten für Kosten und Wissensbasis folgende Regeln:

- **Dynamische Kostenfaktoren (FA-16):** Tokenverbrauch wird je Verfahren in reale Kosten umgerechnet; die Preise stehen in der Data Table `modell_preise`. Lokale Verfahren werden mit Kosten 0 geführt (FA-15).
- **Kostenobergrenze:** `max_kosten` gilt strikt; bei Erreichen stoppt die Eskalation (Budget-Prüfung, Abschnitt 4.8).
- **Lernende Wissensbasis (FA-10, FA-9):** Jeder abgeschlossene Fall wird mit finalem Status Teil der SCORE-DB; verspätete manuelle Korrekturen, etwa aus DATEV, werden dem Ursprungsdatensatz zugeordnet. Per Klärfall korrigierte Fälle bleiben so für Auswertungen und künftige Modelle erhalten; in den Trainingspool der Startstufe gehen sie nicht, weil bei ihnen keine Stufe erfolgreich war und damit das Label „erste erfolgreiche Stufe“ fehlt.
- **Retention (FA-20):** regelmäßige Prüfung auf Redundanz, Alter und Relevanz; sichere Batch-Löschung zu je 10 Datensätzen; einzigartige und seltene Fälle bleiben erhalten.
- **Onboarding neuer Module (FA-21):** Seeding durch Duplikation der Datensätze eines vergleichbaren Bestandsmoduls; echte Ergebnisse verdrängen die Seeding-Daten.
- **Seeding und LightGBM:** Für eine neue Stufe gibt es zunächst kein eigenes Modell, weil unter 100 Fällen nicht trainiert wird; die Startstufe kann sie dann nicht vorschlagen, erreicht wird sie nur über die Eskalation. Duplizierte Seeding-Datensätze liefern sofort Trainingsdaten, das neue Modell übernimmt damit aber genau das Verhalten des Vorbilds. Die Bevorzugung über „Kosten = 0“ wirkt bei LightGBM nicht, weil die Kosten kein Merkmal der Modelle sind; die Reihenfolge der Stufen kommt aus der Registry. Seeding-Fälle sollten deshalb gekennzeichnet und nach den ersten echten Ergebnissen aus dem Training genommen werden.

4.10 KI-Komponente, Validierung und Halluzinations-Notiz

Die KI-Komponenten sind das lokale Vision-Modell (Ollama, glm-ocr) und die Cloud-Stufen (Claude Haiku). Sie erhalten ein festes, feldbasiertes Extraktionsschema statt einer offenen Aufgabe und liefern reines JSON; der Belegtext steht in markierten Datenblöcken und wird im Systemprompt ausdrücklich als Daten gekennzeichnet. Die Belegart wird dagegen nicht von einem LLM bestimmt, sondern regelbasiert (Abschnitt 4.2).

Halluzinations-Notiz: Vision-Modelle erfinden gelegentlich plausible, aber falsche Werte, etwa eine Rechnungsnummer, die auf dem Beleg nicht steht, oder vertauschen Verkäufer und Kunde. SCORE verlässt sich deshalb nicht auf die Selbstauskunft des Modells, sondern prüft jedes Feld unabhängig: Format und Plausibilität (Datum, Beträge, IBAN-Prüfziffer, USt-IdNr), Rechnung (Netto + USt = Brutto), Rechenprüfung (Abschnitt 4.6) und Grounding, also ob der Wert im Tesseract-Text des Belegs tatsächlich vorkommt. Ergebnisse, die diese Prüfung nicht bestehen, eskalieren zur nächsten Stufe; bleibt ein Beleg auch dann unplausibel oder ist das Budget erschöpft, wird nicht geraten, sondern zwingend auf die manuelle Klärung umgeschaltet.

Bekannte Schwäche: Ein Feld gilt bereits als erkannt, wenn es gefüllt ist; auch Platzhalter wie „nicht vorhanden“ werden derzeit als gültiger Wert akzeptiert. Das erhöht die Erfolgsquote, ohne die Richtigkeit zu verbessern. Die Behandlung von Platzhaltern als „nicht erkannt“ ist als Verbesserung vorgemerkt (Kapitel 8).

4.11 Datenquellen und Tests

Entwicklung und Tests laufen ausschließlich mit öffentlichen oder synthetischen Testdaten, nicht mit echten Mandantenbelegen: Bilder von Rechnungen und Kassenbons mit Referenzfeldern aus dem Hugging-

Face-Datensatz `mychen76/invoices-and-receipts_ocr_v1` (60 % der Testmischung, per API mit Wartezeit und Wiederholung geladen; abgelaufene Bild-URLs werden je Download neu abgerufen) sowie deutsche PDF-Belege aus dem GitHub-Repository `JensWalter/my-receipts` (40 %, u. a. Tankstelle, Gastronomie, Elektronikhandel, teils mehrseitig). Für alle 49 Belegarten gibt es zusätzlich selbst erzeugte Testbilder mit typischen Zusatzfeldern und 213 Rechentestfälle (Abschnitt 4.6). Die Massentests umfassen 150, 200, 500 und 97 (GIF) Belege sowie den neuen Test mit 1000 Belegen (Abschnitt 5.2).

4.12 Nachweis erfolgreicher Läufe

Das Audit-Log (eine Zeile je Anfrage mit Status, Modul, Stufen und Kosten), die in `ergebnis_1000.jsonl` gespeicherten Rohdaten des Massentests und die per E-Mail versandten Berichte des Massentests und des Red-Team-Tests belegen die erfolgreichen Läufe. Der Editor-Screenshot der ersten Fassung ist entfallen, weil er den Hauptprozess vor dem Umbau zeigte.

4.13 Betrieb, Monitoring und Übergabe

Betriebs-Steckbrief für SCORE:

Thema	Festlegung
Technischer Betrieb	Produktivbetrieb auf Mac Studio M5 Ultra: Docker-Stack (arm64-Images) für n8n mit drei Task-Runner-Containern, DuckDB, Redis/webdis, Tesseract, LightGBM und Docling; Ollama nativ unter macOS mit Metal-Beschleunigung, weil Container auf macOS die Apple-GPU nicht nutzen können (Zugriff aus den Containern über <code>host.docker.internal:11434</code>). Der Docker-VM wird nur ein Teil des Arbeitsspeichers zugeteilt, der Rest bleibt für die Vision-Modelle frei. Zweites Gerät als Standby (aktiv/passiv) mit regelmäßiger Sicherung der DuckDB-Datei und Replikation von Redis; für echte Lastverteilung ist die Umstellung auf PostgreSQL nötig, weil DuckDB nur einen Schreiber je Datei erlaubt. Nach einem Stromausfall fährt die USV den Mac geordnet herunter; Docker, der Stack (<code>restart: unless-stopped</code>) und Ollama starten automatisch. Betreiber: Frank Arendt (onsite-ki.de) als technischer Betreiber im Rahmen eines Wartungsvertrags.
Fachliche Prüfung	Klärfälle in der Review-UI; eine benannte Fachkraft der Finanzbuchhaltung, Vertretung durch eine zweite Fachkraft
Überwachte Kennzahlen	Klärfall-Quote, Kosten je Beleg (Audit-Log), Treffer der Startstufe, Verdachtsquote der Sicherheitsprüfung, Abweichungsquote der Rechenprüfung, Erfolg des Nachttrainings, Runner-Fehler; Berichte per E-Mail (Metriken-Statistik)
Prüfrhythmus	Klärfälle täglich; Metriken-Bericht wöchentlich; Nachttraining täglich um 02:30 Uhr; Red-Team-Test nach jeder Änderung an Prompts oder Sicherheitsregeln
Fehlerfall	Sicherheitsvorfälle melden sich per Mail „Score security incident“; bei Ausfall des LightGBM-Dienstes startet jeder Beleg bei Tesseract; bei einem abgebrochenen Task-Runner (im Massentest 5 % der Ausführungen) muss der Aufrufer die Anfrage wiederholen; im Produktivbetrieb übernimmt bei Ausfall des ersten Geräts das zweite Gerät als Failover die gesamte Verarbeitung; fehlt die Budget-Antwort, geht der Fall in die Nachbearbeitung. Eskalationskette: zuerst technischer Betreiber (Frank Arendt), bei Sicherheitsvorfall oder Ausfall über einen Arbeitstag zusätzlich die Kanzleileitung (Dr. Marion Hoffmann).
Wartung	Preise in <code>modell_preise</code> bei Preisänderungen der Anbieter pflegen; Workflows nach Änderungen nach <code>~/Score/workflows/</code> exportieren; Sicherungen vor dem Live-Swap vom 8. Oktober unter <code>live_swap/backup_vor_Umstellung_2026-10-08/</code>

Übergabe-Checkliste:

1. Zugänge übergeben: n8n, Webmail für die Berichte, Credentials der Cloud-Anbieter mit Ablaufdatum
2. Einweisung der Kanzlei in die Review-UI (Klärfall prüfen, korrigieren, freigeben)

3. Notfallkarte ausgehängt: Ansprechpartner, Abschaltung der Cloud-Stufen, Vorgehen bei „Score security incident“
4. Stromausfall prüfen

Wartungsaufgaben:

Thema	Hinweis
Quelltexte und Tests	<code>~/Score/redteam/</code> : Detektor, Sicherheitsprüfung, Testgenerator, Testskripte, 29 synthetische Testbilder. Katalog, Klassifikator, Rechenprüfung und Testgeneratoren liegen unter <code>score/belegkatalog/</code> . Tests laufen im n8n-Container (Node.js mit Jimp).
Codeänderungen	Quelle der Wahrheit ist die Datei (z. B. <code>belegklassifikation.template.js</code> , per <code>build.py</code> in den Code-Node übernommen); nach Änderung Unit-Tests lokal und gegen den bereitgestellten Code ausführen, danach Export der Workflows nach <code>~/Score/workflows/</code> . Ein Import in n8n deaktiviert den Workflow; er ist danach wieder zu aktivieren.
Startstufen-Modell	Das Training läuft nachts um 02:30 Uhr automatisch. Die Schwelle (derzeit 0,6) wird im Submodul „Startstufe LightGBM“ gepflegt; nach Änderungen den Vergleich gegen kNN und „immer Stufe 2“ wiederholen.
Testdaten	Test-Datensätze nach Live-Tests aus <code>score_db</code> löschen oder kennzeichnen, damit sie nicht in den Trainingspool der Startstufe oder den kNN-Pool gelangen (aktuell offen für die 1000 Massentestfälle). Redis-Fälle laufen nach 8 Wochen von selbst ab.
Berichte	HTML-Berichte per E-Mail; Konfiguration aus „SCORE – Metriken-Statistik“ (Format „both“). Extrahierter Text in Berichten ist HTML-zu-escapen.

5. Ergebnisse

5.1 Testergebnisse

Test	Ergebnis
Massentest 1000 Belege (07./08.10.2026)	934 erfolgreich (93,4 %), 66 manuelle Nachbearbeitung, 0 ohne Ergebnis; Kosten 1,07 € gesamt; Median 39 s (Details in Abschnitt 5.2)
Rechnerische Validierung (07.10.2026)	213 Testfälle, 49 von 49 Belegarten; Fehlererkennung 92 von 92 (Text) bzw. 90 von 92 (OCR Produktion), Fehlalarme 0
Red-Team-Workflow (18 Angriffs- und 6 Kontrollbelege, shadow)	Erster vollständiger Lauf: 17 von 18 Angriffen erkannt, 0 von 6 Fehlalarmen; Lücke: IBAN nur in versteckter Schrift. Nach Verschärfung der Regel, auf der Architektur mit Submodulen am 29.09.2026 und im Live-Hauptprozess nach der Umstellung am 08.10.2026: 18 von 18 Angriffe erkannt, 0 von 6 Fehlalarme. Im Shadow-Modus werden Befunde gemessen, aber nicht durchgesetzt.
Detektor, synthetische Bilder	17 von 17 versteckten Texten erkannt; 0 von 9 Fehlalarmen
Detektor, echte Rechnungsscans	20 von 20 erkannt bei 3, 6, 10, 15 und 25 Graustufen Differenz; 0 von 60 Fehlalarmen
Sicherheitsprüfung, Unit-Tests	32 von 32 bestanden, lokal und gegen den bereitgestellten Code
A/B-Test Bildkorrektur (60 Kassenbons)	Ohne Bildkorrektur Laufzeit bei den 15 betroffenen Belegen von 20,8 s auf 12,6 s (–40 %), Felder unverändert (28 von 54 in beiden Varianten) → im Live-Hauptprozess abgeschaltet
A/B-Test GIF als PNG (60 Kassenbons)	Ø 14,0 s → 7,3 s (–48 %), Feldtreffer unverändert (130 gegen 129 von 202) → live

GIF-Massentest (97 Belege, 30.09.2026)	82 von 97 erfolgreich (84,5 %), 15 Klärfälle wegen des damals unerfüllbaren Pflichtfelds „client“ auf Kassenbons (seit der Belegart-Architektur entfällt es dort); Startstufe: LightGBM 88,0 %, kNN 77,1 %, „immer Stufe 2“ 90,4 %; Kosten 0,136 € gesamt, 0,14 Cent je Beleg
Kreuzvalidierung Startstufe (5-fach)	LightGBM 77,1 %, kNN 62,7 % Treffer
Hauptprozess, Workflow-Validierung	0 Fehler

Details: Testprotokoll Prompt-Injection-Schutz vom 29.09.2026, Gesamtbericht vom 08.10.2026.

5.2 Massentest mit 1000 Belegen

Aufbau: 600 Kassenbons (Hugging Face, Singapur, englisch, als GIF in Originalgröße, damit der Docling-Schnellpfad umgangen wird) und 400 deutsche PDFs (GitHub, Docling-Pfad, Seed 2026). Konfiguration: `strategie: cost`, `max_kosten: 0,05`, Startstufe per LightGBM, Bildkorrektur abgeschaltet, Rechenprüfung im Shadow-Modus; VIES und Sicherheitsmails waren abgeschaltet. Treiber: 2 Worker, ab dem 57. Beleg 3 Worker. Getestet wurde eine Kopie des Hauptprozesses mit der Belegart-Architektur, die inzwischen live ist.

Quelle	Belege	erfolgreich	manuell	Ø Kosten	Median	P90	max
Kassenbon (GIF)	600	97,3 %	16	0,00106 €	15 s	54 s	258 s
PDF (Docling-Pfad)	400	87,5 %	50	0,00107 €	105 s	180 s	345 s
alle	1000	93,4 %	66	0,00107 €	39 s	149 s	345 s

Letzte Stufe: Claude Haiku (Gateway) 84,4 %, glm-ocr 6,5 %, Docling 6,0 %, Claude Haiku direkt 1,7 %, Tesseract 1,4 %. 64,4 % der Belege brauchten eine Stufe, 26,0 % vier Stufen. Der hohe Cloud-Anteil kommt wesentlich aus dem Beleg-Mix (englische GIF-Kassenbons), erlaubt aber keinen Schluss auf deutsche Mandantenbelege.

Belegarten: UNBEKANNT 46,9 %, Kleinbetragsrechnung 16,4 %, Import 14,6 %, Bewirtschaftungsbeleg 7,4 %, Kassenbeleg 4,1 %, Fahrausweis 4,0 %, Rechnungskorrektur 2,3 %, Standardrechnung 1,2 %, übrige zusammen 3,1 %. Das war die Vorversion des Klassifikators; Version 2 (Abschnitt 4.2) senkte UNBEKANNT auf einer Stichprobe von 118 Belegen auf 31 %. Für die Belegart liegt keine Ground Truth vor.

Feldrichtigkeit gegen die Ground Truth (nur Kassenbons)

Feld	richtig	bewertet	Genauigkeit
brutto	250	358	69,8 %
netto	161	391	41,2 %
ust_betrag	170	367	46,3 %
invoice_date	304	509	59,7 %
seller	298	421	70,8 %

Bewertet werden nur Felder, für die die Ground Truth einen Wert hat. Die Genauigkeit liegt nach Belegart sehr unterschiedlich (Kleinbetragsrechnung: Brutto 90,9 %; UNBEKANNT: Netto 28,4 %), je besser die Belegart erkannt wurde, desto besser die Felder. Für PDFs gibt es keine Ground Truth. **Folgerung:** Die Quote „ohne Klärfall“ überschätzt die Qualität. Von den Zusatzfeldern wird Brutto je Belegart in rund 78 bis 98 % der Fälle erfasst, Netto und USt-Betrag in etwa 30 bis 83 %, die IBAN selten (0 bis 25 %; auf Kassenbons meist nicht vorhanden, bei Kontoauszügen 6 von 6).

Sicherheitsprüfung auf realen Belegen

Im Shadow-Modus markierte die Sicherheitsprüfung je nach Belegart 25 bis 83 % der Belege als Verdachtsfall (UNBEKANNT 72,3 %, Kleinbetragsrechnung 54,9 %, Import 69,2 %, Rechnungskorrektur 82,6 %). Häufigste Befunde waren `grounding_fehlt` (Wert nicht im OCR-Text, meist OCR-Lesefehler), `versteckter_text_verdacht`, `summe_stimmt_nicht` und `urls` (Webadressen auf Fahrscheinen und Korrekturbelegen). Wären diese Regeln im Enforce-Modus aktiv gewesen, hätten sie einen Großteil der Belege in den Klärfall geschickt. Das Umschalten auf Enforce setzt deshalb eine Kalibrierung voraus (Schwellen je Befundart, Grounding mit Toleranz für OCR-Fehler, URLs auf Belegen als normal).

Rechenprüfung

Siehe Abschnitt 4.6. Zusammengefasst: 51 Abweichungen R07, 12 R02, 8 R01, 5 R08 (unzulässiger Steuersatz wie 12,5 oder 20 %, meist Singapur-Belege), je 1 R05, R09, R28.

5.3 Kennzahlen und Wirtschaftlichkeit

Kennzahlen im Vergleich (Standard einer mittelgroßen Steuerkanzlei mit 200 bis 400 FiBu-Mandaten, 70 bis 120 Belegen je Mandat, rund 30.000 Belegen im Monat; Branchenschätzung, eigene Recherche):

Kennzahl	Ist (Branche)	Soll	SCORE	Herkunft	Bewertung
Dunkelverarbeitung	60 – 80 % (typisch 70 – 80 %)	85 %	93,4 % (Massentest)	gemessen	Quote ohne Klärfall; nicht gleichbedeutend mit „richtig“ (Feldrichtigkeit auf Testbons 41 – 71 %). Die Rechnung nimmt konservativ 87 % an; ob das auf echten Belegen hält, zeigt der Pilot mit geprüfter Stichprobe.
Bearbeitungszeit je Klärfall	2,0 – 3,0 Min.	< 1,2 Min.	< 1,2 Min.	Annahme	im Pilot per Stoppuhr zu messen
IDP-/OCR-Kosten je Beleg	0,10 – 0,50 € (typisch 0,30 €)	deutlich < 1 Cent	0,107 Cent (Massentest); 0,03 – 0,16 Cent über alle Tests	gemessen	erreicht, rund 1 % der IDP-/OCR-Kosten; gerechnet wird konservativ mit 0,16 Cent
Feldrichtigkeit gegen Ground Truth	~ 92 – 95 % (Branche)	–	41 – 71 % (nur Kassenbons)	gemessen (08.10.)	auf englischen Singapur-Kassenbons; nicht repräsentativ und nicht mit der Branchenspanne vergleichbar. Die in der ersten Fassung genannten 95,5 – 96,1 % bezogen sich auf erkannte Felder in <code>score_db</code> , nicht auf einen Abgleich mit Ground Truth.
Durchsatz, Normalbetrieb (30.000 Belege über 21 Arbeitstage à 12 Std. = 119 Belege/Std.)	–	≥ 119/Std.	170 – 190/Std.	gemessen (Massentest, 3 Worker)	erreicht, auf dem CPU-Testrechner (12 Kerne, 31 GB). Median je Beleg 39 s (Kassenbon 15 s, PDF 105 s).
Durchsatz, Spitzenlast (Monatsvolumen in 12 Std. = 2.500 Belege/Std.)	–	≥ 2.500/Std.	170 – 190/Std.	gemessen	nicht erreicht (Faktor 13 bis 15); Parallelisierung, zweites Gerät und GPU für die lokalen Stufen nötig

Durchsatz statt Antwortzeit je Beleg: Verteilen sich die 30.000 Belege gleichmäßig auf 21 Arbeitstage mit 12 Stunden Betrieb, müssen rund 119 Belege je Stunde verarbeitet werden ($30.000 \div 252 \text{ h}$). Das

Monatsvolumen in 12 Stunden entspricht 2.500 Belegen je Stunde ($30.000 \div 12 \text{ h}$). Die erste Fassung hatte stattdessen eine Antwortzeit von höchstens 30 s je Beleg angesetzt und aus dem sequenziellen GIF-Test (33 s) abgeleitet; mit parallelen Workern ist der Durchsatz die passende Größe.

Wo die Zeit hingeht (Auswertung der n8n-Knotenzeiten für 732 der 1000 Belege; n8n bewahrt nur die letzten rund 10.000 Ausführungen auf): 79 % der Rechenzeit entfallen auf drei Stellen: das lokale Vision-Modell Ollama (40 %; $\varnothing$ 67 s je Aufruf), die Docling-Extraktion der PDFs (23 %; $\varnothing$ 32 s) und die statische Bildanalyse (17 %; $\varnothing$ 15 s). Claude Haiku braucht dagegen $\varnothing$ 1,5 s je Aufruf. Ollama und Docling teilen sich auf dem Testrechner dieselbe CPU und bremsen sich: Die Dauer eines Ollama-Aufrufs stieg von 27 s allein auf 107 s mit drei weiteren gleichzeitigen Aufrufen. Mehr parallele Worker bringen deshalb nur begrenzt etwas; ob drei gegenüber zwei Workern den Durchsatz erhöhen, ist nicht kontrolliert gemessen. Auf dem Mac Studio mit GPU-Beschleunigung sind diese Zeiten voraussichtlich deutlich kürzer; gemessen ist das noch nicht. Ollama-Belege über Claude Haiku hätten im Massentest etwa 0,24 € gekostet und rund 6 statt 265 Minuten gedauert (Hochrechnung, Qualität nicht verglichen); das ist der Hintergrund der Priorität **zeit** (Abschnitt 4.3).

Zuverlässigkeit: 38 von 732 Ausführungen (5 %) endeten mit Task-Runner-Fehlern („runner became unresponsive“), vor allem in der Bildaufbereitung und beim Check auf versteckten Text (beide rechnen mit Jimp und blockieren den Runner). Der Testtreiber hat die Anfragen wiederholt; am Ende gab es 0 Ausfälle. Die Umstellung auf drei externe Runner beseitigt das Problem nicht vollständig. Ein produktiver Aufrufer braucht eine Wiederholungslogik, oder die Bildverarbeitung läuft auf einem eigenen Runner.

Feld-Erkennung im Zeitverlauf (Stand 30.09.): Die Rechnungsnummer stieg von 86,2 % (bis 21.09.) auf 96,1 % (ab 22.09.), der Verkäufer von 80,4 % auf 95,9 %; das Datum blieb bei rund 95,5 %. Das sind Anteile erkannter Felder, kein Abgleich mit Ground Truth. Die niedrigen Raten beim Modul Tesseract betreffen vor allem Belege, bei denen die Eskalation nicht weiterging (etwa wegen `max_kosten = 0`), und messen nicht die Lesequalität von Tesseract.

Kostenannahmen (Region Baden-Württemberg): Bruttogehalt einer Steuerfachangestellten 45.000 € im Jahr, zuzüglich rund 22 % Arbeitgeberanteil (54.900 €) und rund 20 % des Bruttos für den Arbeitsplatz. Daraus ergeben sich Vollkosten von rund 63.900 € je Vollzeitskraft und bei 1.650 produktiven Stunden ein Stundensatz von rund 39 €. Rechengrundlage sind 360.000 Belege im Jahr.

Personalbedarf aus den Kennzahlen: Der Klärfall-Aufwand ergibt sich aus Anteil der Klärfälle $\times$ Bearbeitungszeit je Fall.

	Ist (typisch)	Soll mit SCORE
Anteil Klärfälle	25 % (Dunkelverarbeitung 75 %)	13 % (Dunkelverarbeitung 87 %)
Klärfälle im Monat	7.500	3.900
Zeit je Klärfall	2,5 Min.	1,2 Min.
Klärfall-Aufwand im Monat	312,5 Stunden	78 Stunden (rund 25 % des Ist-Aufwands)
Personal	2,5 Vollzeitkräfte	0,62 Vollzeitkräfte ($2,5 \times 78 \div 312,5$)

Die 2,5 Vollzeitkräfte leisten rund 345 produktive Stunden im Monat, der reine Klärfall-Aufwand beträgt 312,5 Stunden; die Differenz entfällt auf Rüst- und Nebenzeiten. Der Soll-Bedarf wird deshalb proportional zum heutigen Einsatz skaliert, nicht aus den reinen Bearbeitungsstunden.

Kostenblock pro Jahr	Ist	Soll mit SCORE
Personal für Klärfälle	2,5 Vollzeitkräfte = 159.750 €	0,62 Vollzeitkräfte = 39.900 €
Erkennung (IDP/OCR bzw. SCORE)	0,30 € je Beleg = 108.000 €	0,0016 € je Beleg = 576 €
Summe	267.750 €	rund 40.500 € zuzüglich Betrieb und Wartung

Einordnung: Das Einsparpotenzial liegt bei rund 227.300 € im Jahr, etwa 85 % der heutigen Kosten: rund 119.900 € beim Personal und rund 107.400 € bei der Erkennung. Mit den gemessenen Kosten von 0,107 Cent je Beleg stiege die Einsparung gegenüber der Rechnung mit 0,16 Cent nur um rund 190 €; das Ergebnis hängt also kaum an der Kostenschwankung der Tests. Die freigesetzte Kapazität von rund 1,9 Vollzeitkräften kann die Kanzlei für Beratung statt Erfassung einsetzen. Laufende Kosten für Betrieb und Wartung sind noch abzuziehen.

Investitionskosten: Für den Produktivbetrieb mit lokalen Modellen ist leistungsfähige Hardware vorgesehen; die Preise sind vor der Beschaffung per Angebot zu bestätigen.

Position	Umfang	Kosten
Apple Mac Studio mit M5 Ultra im Vollobau, einschließlich unterbrechungsfreier Stromversorgung (USV)	ein Gerät	rund 20.000 – 25.000 €
Zweites Gerät, vorwiegend als Failover bei Ausfall des ersten Geräts, zusätzlich zur Lastverteilung bei Spitzenlast	optional	rund 20.000 – 25.000 €
Investition gesamt	ein bis zwei Geräte	20.000 – 50.000 €

Kennzahl	ein Gerät (20.000 €)	zwei Geräte (50.000 €)
Abschreibung je Jahr bei 3 Jahren Nutzung	rund 6.700 €	rund 16.700 €
Einsparung je Jahr nach Abschreibung	rund 220.600 €	rund 210.600 €
Amortisation der Investition	gut 1 Monat	knapp 3 Monate

Die Amortisation bezieht sich auf das Einsparpotenzial von rund 227.300 € im Jahr; laufende Kosten für Strom, Betrieb und Wartung sind noch nicht enthalten. Steuerlich ist für Computerhardware nach dem BMF-Schreiben zur Nutzungsdauer digitaler Wirtschaftsgüter auch eine Nutzungsdauer von einem Jahr zulässig; die Einzelheiten klärt die Kanzlei in eigener Sache.

Grenzen der Rechnung: Die SCORE-Werte für Kosten je Beleg sind gemessen; die Kosten je Beleg schwanken je Testlauf zwischen 0,03 und 0,16 Cent. Die Dunkelverarbeitung ist als Quote ohne Klärfall gemessen, ihre Richtigkeit nur auf Testbons (Abschnitt 5.2). Die Bearbeitungszeit je Klärfall von unter 1,2 Minuten ist eine Annahme; der Personalbedarf skaliert direkt mit ihr (bei 2 Minuten wären es rund 1,0 statt 0,62 Vollzeitkräfte). Wären nur 80 statt 87 % der Belege tatsächlich korrekt dunkel verarbeitet, stiege der Klärfall-Aufwand entsprechend (rechnerisch auf rund 20 % Klärfälle und etwa 0,96 Vollzeitkräfte bei 1,2 Minuten). Voraussetzung für die volle IDP-/OCR-Einsparung ist, dass SCORE den bisherigen Dienst vollständig ersetzt. Belastbare Werte liefert ein Pilot mit Stoppuhr-Messung und manuell geprüfter Stichprobe.

5.4 Risiko-Bilanz

Risiko	Bewertung	Gegenmaßnahme
Feldrichtigkeit auf echten Belegen niedriger als die Erfolgsquote nahelegt	hoch	Pilot mit manuell geprüfter Stichprobe; Platzhalter nicht als erkannt zählen; Rechenprüfung und Grounding als Plausibilisierung; Klärfall bei Abweichung
Zeit je Klärfall höher als angenommen	mittel	Stoppuhr-Messung im Pilot; bei 2 Minuten bleibt die Einsparung mit rund 1,0 statt 0,62 Vollzeitkräften deutlich
Spitzenlast zum Monatsende	mittel	zweites Gerät, GPU für lokale Stufen, mehrere Worker, Priorität zeit
Task-Runner-Abbrüche (5 % im Massentest)	mittel	Wiederholung durch den Aufrufer; Bildverarbeitung auf eigenem Runner; Abbau der blockierenden Jimp-Schritte (GIF→PNG ist live)

Abhängigkeit von Preisen und Verfügbarkeit der Cloud-Anbieter	mittel	drei austauschbare Cloud-Stufen, Preise in <code>modell_preise</code> , strikte Kostenobergrenze
Verfälschte Lernbasis (manipulierte, <code>quality</code> - oder Testfälle im Training)	mittel	Verdachts- und <code>quality</code> -Fälle sind aus Kandidatenpool und Training ausgeschlossen; Massentestfälle noch zu bereinigen; Poisoning-Test offen
Manipulierte Belege (Prompt Injection)	mittel	Sicherheitsprüfung mit Vorfilter, Grounding und Klärfall (Abschnitt 7.5); Kalibrierung, dann Umschalten auf Enforce
Ausfall der Hardware	mittel	zweites Gerät als Failover, USV, automatischer Neustart
Kaltstart neuer Module	niedrig	Seeding mit Kennzeichnung, Erreichbarkeit über die Eskalation
Akzeptanz im Team	mittel	frühe Einbindung, Schulung auf die Review-UI (Kapitel 6)

6. Change Management

6.1 Stakeholder-Map

Stakeholder	Einfluss	Betroffenheit	Maßnahme
Partner und Berufsträger	hoch	verantworten Qualität und Haftung, entscheiden über Pilot, Budget und Hardware	wöchentliches Kurz-Update zu Dunkelverarbeitung, Kosten und offenen Fällen; Freigabe der Kostenobergrenze
Fachkräfte der Finanzbuchhaltung	hoch	Tätigkeit ändert sich am stärksten: weniger Erfassung, mehr Prüfung; Sorge um den eigenen Arbeitsplatz	frühe Einbindung, Schulung auf die Review-UI, klare Botschaft: freigesetzte Zeit geht in Beratung und Mandantenbetreuung
Mandanten	mittel	indirekt über Bearbeitungsgeschwindigkeit und Datenschutz ihrer Belege	keine aktive Kampagne; auf Nachfrage Erläuterung der Verarbeitung und der Cloud-Eskalation
IT-Betreuung / externer Betreiber	mittel	betreibt Hardware, Stack und Wartung	Einbindung in Übergabe-Checkliste und Failover-Test
Datenschutzbeauftragte/r	mittel	prüft VVT, DSFA und Auftragsverarbeitung	Einbindung vor dem Pilot (Kapitel 7)
DATEV	niedrig	Ziel der Buchungen	rein technische Abstimmung

6.2 Kommunikationsplan

Zeitpunkt	Zielgruppe	Kanal	Inhalt
vor dem Pilot	Partner	Besprechung	Ziel, Kennzahlen, Investition, Entscheidung über den Pilot
Pilotstart (Woche 1)	Fachkräfte Finanzbuchhaltung	Kick-off und Schulung	Zweck, Ablauf, Arbeit mit der Review-UI (einschließlich Anzeige der Rechenprüfung), Umgang mit Klärfällen
Woche 1 bis 4	Partner	kurzer Wochenbericht per E-Mail	Dunkelverarbeitung, Zeit je Klärfall, Kosten, Auffälligkeiten
Woche 2	Fachkräfte	kurze Feedbackrunde	Erfahrungen mit der Review-UI, Verbesserungswünsche

Leitgedanke: Die Automatisierung entlastet, sie ersetzt nicht. Wer künftig vor allem prüft statt tippt, braucht ein Grundverständnis, wie die Startstufe, die Belegart-Zuordnung und die Prüfregeln entscheiden, um Fehlvorschläge sicher zu erkennen. Diese KI-Kompetenz ist zugleich Pflicht nach Art. 4 EU AI Act.

7. Datenschutz und Sicherheit

7.1 Verzeichnis von Verarbeitungstätigkeiten

Die Belegerkennung ist als eigener Eintrag im Verzeichnis von Verarbeitungstätigkeiten der Kanzlei zu führen: Zweck (automatisierte Belegerkennung für die Finanzbuchhaltung der Mandanten), betroffene Personen (Mandanten und deren Geschäftspartner, soweit auf Belegen erkennbar), Daten (Bild- und PDF-Belege, extrahierte Rechnungsfelder; bei Einzelunternehmen und Freiberuflern regelmäßig personenbezogene Daten wie Name, Anschrift und IBAN), Empfänger (lokale Verarbeitung; bei Eskalation Cloud-Anbieter als Auftragsverarbeiter; bei der USt-IdNr.-Prüfung der EU-Dienst VIES), Löschfristen (Klärfall-Cache 8 Wochen; Audit-Log ohne Bild, nur Prüfsumme; Prüfprotokolle nach der Archivierungsfrist der Kanzlei) und Rechtsgrundlage (Abschnitt 7.2).

7.2 Rechtsgrundlage, Berufsgeheimnis und DSFA-Skizze

Rechtsgrundlage ist gegenüber den Mandanten regelmäßig Art. 6 Abs. 1 lit. b DSGVO (Erfüllung des Steuerberatungsmandats); für Daten von Geschäftspartnern der Mandanten auf den Belegen kommen lit. c (steuerliche Aufzeichnungspflichten) und lit. f (berechtigtes Interesse an effizienter Bearbeitung) in Betracht.

Berufsgeheimnis: Als Steuerberatungskanzlei unterliegt Hoffmann & Partner der Verschwiegenheitspflicht nach § 57 StBerG und § 203 StGB. Werden Belege an Cloud-Anbieter eskaliert, sind diese als Dienstleister nach § 62a StBerG sorgfältig auszuwählen und in Textform zur Verschwiegenheit zu verpflichten; ein AV-Vertrag nach Art. 28 DSGVO allein genügt dafür nicht.

Für eine Datenschutz-Folgenabschätzung sprechen der Einsatz neuer Technologie (KI-gestützte Bilderkennung), die automatisierte Bewertung der Ergebnisse und die Übermittlung an externe Anbieter bei Eskalation; dagegen sprechen, dass weder Mandanten profiliert noch Entscheidungen mit Rechtswirkung gegenüber Personen getroffen werden. Empfehlung: vor dem Produktivstart eine förmliche DSFA nach Art. 35 DSGVO durchführen oder den Verzicht dokumentiert begründen. Die Einordnung ersetzt keine Rechtsberatung.

7.3 Einordnung nach dem EU AI Act

SCORE ist nach vorläufiger Einschätzung ein KI-System mit minimalem Risiko: keine verbotene Praxis, keine Hochrisiko-Kategorie nach Anhang III (weder Beschäftigung noch Kreditwürdigkeit noch kritische Infrastruktur) und keine Transparenzpflicht nach Art. 50, da keine Interaktion mit natürlichen Personen stattfindet. Als Betreiber hat die Kanzlei die KI-Kompetenz ihrer Beschäftigten sicherzustellen (Art. 4). Die Einordnung ist vor dem Produktivstart rechtlich zu bestätigen.

7.4 Technisch-organisatorische Maßnahmen (TOMs)

Maßnahme	Umsetzung
Datenminimierung	statische Bildanalyse ohne OCR-Vorabaufwurf; Cloud-Eskalation nur bei Bedarf; Feldlängen begrenzt; Audit-Log ohne Bild

Lokalitätsprinzip	Tesseract, Docling und Ollama verarbeiten Belege vollständig lokal. An eine Cloud-Stufe geht ein Beleg nur, wenn die lokalen Stufen ihn nicht sicher erkennen. Im Massentest vom 8. Oktober endeten 86 % der Belege bei einer Cloud-Stufe (Claude Haiku 84,4 % und 1,7 %), im Trainingspool ohne Docling-Fälle rund zwei Drittel. Der Anteil hängt stark vom Beleg-Mix ab (englische GIF-Kassenbons mit schwacher lokaler Erkennung). Diesen Anteil zu senken, ist Ziel des Proof of Concept mit großen Open-Weight-Modellen.
Berufsgeheimnis	Verpflichtung der Cloud-Anbieter zur Verschwiegenheit nach § 62a StBerG; bis dahin keine Eskalation echter Mandantenbelege in die Cloud
Löschkonzept	Klärfall-Cache mit 8 Wochen Aufbewahrung; Audit-Log speichert nur die Prüfsumme der Eingabe, nicht das Bild; kontrollierte Batch-Löschung in der Wissensbasis
Auftragsverarbeitung	AV-Verträge mit Gateway, OpenRouter und Anthropic; Drittlandübermittlung prüfen und über Standardvertragsklauseln absichern
Testdaten	Entwicklung und Tests nur mit öffentlichen oder synthetischen Datensätzen
Zugriffskontrolle	Review-UI nur für befugte Fachkräfte; n8n-Zugänge personenbezogen; Credentials mit Ablaufdatum
Isolation	ein Container je Komponente; Datenbank nur im internen Netz erreichbar
Integrität und Nachvollziehbarkeit	Audit-Log je Anfrage; Sicherheitsprüfung mit Meldung „Score security incident“; USt-IdNr.-Prüfprotokoll mit Hash-Kette
Verfügbarkeit	zweites Gerät als Failover, USV, automatischer Neustart, regelmäßige Sicherung

7.5 Schutz gegen Prompt Injection

7.5.1 Architekturprinzip

Prompt Injection lässt sich im Modell nicht zuverlässig verhindern, nur in der Architektur begrenzen. Ein manipulierter Beleg soll daher höchstens falsche Feldwerte erzeugen können, die deterministisch abgefangen werden. Die Extraktionsmodelle der Eskalationsleiter haben keine Tools, keinen Datenbankzugriff und keine Aktionen; sie liefern reines JSON, das per Code validiert wird. Jede Wirkung entsteht erst nach dieser Validierung.

7.5.2 Schutzschichten

Schicht	Funktion	Status
Detektor versteckter Text	Erkennt Schwach-Tinte-Text (fast weiß auf weiß): lokaler Hintergrund je Kachel (75. Perzentil), Differenz zum Grauwert, Ausschluss sichtbarer Tinte, zeilenartige Bänder mit Textdichte und Laufstruktur. Filter gegen JPEG-Ringing, Rauschen, senkrechte Scanränder und Tabellenlinien (Lauf längentest). Laufzeit ca. 300 ms je A4-Scan (2481 × 3508 px). Läuft auf dem Originalbild vor dem Vorfilter.	aktiv (Shadow)
Vorfilter	Prüft vor jeder LLM-Stufe den Tesseract-Text auf Instruktionsmuster (Deutsch und Englisch) und Auffälligkeiten wie zusammenhängenden Fließtext. Fälle, die direkt bei Ollama oder einem LLM starten, erhalten dafür einen zusätzlichen Tesseract-Aufruf.	aktiv (Shadow)
Ergebnisprüfung	Je extrahiertem Feld: Datumsplausibilität, IBAN-Prüfziffer, Format der USt-IdNr, Beträge, Netto + USt = Brutto, Längen- und Markup-Grenzen, Grounding (Wert muss im Tesseract-Text vorkommen). Abweichende Namen erzeugen nur eine Warnung.	aktiv (Shadow)
Prompt-Härtung	Belegtext in markierten Blöcken (<code><beleg_inhalt></code>), Systemprompt kennzeichnet ihn als reine Daten.	umgesetzt
SQL-Injection	Vorfilter erkennt SQL-Schlüsselwörter im Belegtext (auch auf dem Docling-Pfad); ein Treffer erzwingt den Klärfall ohne LLM-Aufruf, in jedem Modus. Werte werden parametrisiert übergeben.	aktiv

Feldlängen	Erkannte Felder werden auf <code>feld_limits</code> gekürzt (Standard 14 Zeichen, per JSON-Schema im Request bis 500); die Sicherheitsprüfung sieht die Werte vor dem Kürzen.	aktiv
Schutz der Lernbasis	Die View <code>v_erfolgreiche_faelle</code> schließt Fälle mit <code>sicherheits.flag_verdacht = true</code> und Fälle der Strategie <code>quality</code> aus Training, kNN-Pool und <code>fuzzy_match</code> aus. Offen: ein Poisoning-Test.	umgesetzt

7.5.3 Umsetzung

- Submodul „SCORE – Sicherheitsprüfung (Submodul)“, n8n-ID `HV4Ii5GmdYQQAlTM`; Quelltext `~/Score/redteam/sicherheitspruefung.js`. Eingabe mit `phase` (`vorfilter` oder `ergebnis`), OCR-Text, erkannten Feldern und optional dem Verdacht auf versteckten Text; Ausgabe mit Modus, Verdachts-Flag und Aktion (`weiter` oder Klärfall).
- Einbindung im Hauptprozess (FA-11, n8n-ID `5qNPDgUeA1BV9v9`) an den Aufrufstellen „Sicherheits-Vorfilter Aufruf“, „Docling Sicherheits-Vorfilter Aufruf“ und „Sicherheits-Ergebnis Aufruf“.
- Red-Team-Workflow „SCORE – Red-Team Test (Sicherheit)“: sendet ein Testset aus Angriffs- und Kontrollbelegen über den Hauptprozess, misst je Kategorie den Anteil Verdacht und Klärfall sowie die Fehlalarmrate der Kontrollen und versendet einen HTML-Bericht per E-Mail. Nach der Umstellung auf die Belegart-Architektur lief er im Live-Hauptprozess mit 18 von 18 erkannten Angriffen und 0 von 6 Fehlalarmen. Dabei war ein hartkodierter Schriftpfad der Testbeleg-Erzeugung im externen Runner nicht vorhanden; er wurde so angepasst, dass beide Pfade geprüft werden.
- Speicherung der Befunde je Datensatz in `daten_json.sicherheits`.
- Detektor als eigenständiges Modul `~/Score/redteam/versteckter_text.js`; läuft auf dem Originalbild. Die Ausgabe fließt nur in die Sicherheitsprüfung, nicht in `messgroessen_json`.

7.5.4 Betriebsmodus

Der Modus wird über die Konstante `MODUS` im Submodul gesteuert. **shadow** (aktuell): Befunde werden gemessen und gespeichert, Status und Verarbeitung bleiben unverändert. **enforce**: Verdachtsfälle werden zum Klärfall und laufen über den bestehenden Klärfall-Pfad (Redis, E-Mail, Review-Oberfläche). SQL-Treffer erzwingen den Klärfall in beiden Modi. Sicherheitsvorfälle lösen die Mail „Score security incident“ an die Demo-Adresse aus; `sicherheits.sicherheitsvorfall` und `sicherheits.sql_injection` stehen in `daten_json` und in der API-Antwort. Das Umschalten auf enforce ist erst nach der Shadow-Kalibrierung und dem Test mit fotoähnlichen Bildern vorgesehen. Der Massentest hat gezeigt, dass die Verdachtsquote auf realen Belegen in vielen Belegarten über 50 % liegt (Abschnitt 5.2); ohne Kalibrierung würde enforce den Klärfall-Anteil stark erhöhen.

7.6 Threat-Model und weiterführende Absicherung

Die folgenden Punkte leiten sich aus dem Workshop-Handout des SIBB e. V. vom 28.09.2026 ab und ergänzen die Maßnahmen aus Abschnitt 7.5. Sie sind als Vorschläge zu verstehen; die rechtlichen Hinweise des Handouts sind eine Orientierungshilfe und keine Rechtsberatung.

7.6.1 Designentscheidung: die „tödliche Dreierkombination“ vermeiden

Prompt Injection wird erst zum Schaden, wenn drei Eigenschaften zusammentreffen: nicht vertrauenswürdige Eingaben, Zugriff auf sensible Daten und ein Kanal nach außen (nach Simon Willison, „lethal trifecta“). Die wirksamste Gegenmaßnahme ist, eine der drei zu streichen.

Eigenschaft	In SCORE
Fremde Inhalte	vorhanden und unvermeidbar: Belege stammen von Dritten
Sensible Daten	vorhanden: Rechnungsdaten, IBAN, ggf. personenbezogene Angaben

Kanal nach außen	bewusst gestrichen: Die Extraktionsmodelle haben keine Tools, keinen Datenbankzugriff und keinen Sendeweg. Restkanäle sind HTML-Berichte, Klärfall-Mails und die Review-Oberfläche; dort wird extrahierter Text escaped und nur als Text dargestellt, externe Bilder und Links sind nicht zugelassen.
------------------	---

7.6.2 Prüfung gegen die OWASP Agentic Top 10

Risiko	Bezug in SCORE	Status
ASI01 Agent Goal Hijack	Prompt Injection über Belege; Vorfilter, Ergebnisprüfung und Grounding (Abschnitt 7.5), derzeit im Shadow-Modus	teilweise (bis Enforce)
ASI02 Tool Misuse	entfällt: keine Tools für die Modelle	erfüllt
ASI03 Identity & Privilege Abuse	DuckDB nur im internen Netz erreichbar, Werte parametrisiert; offen sind getrennte Lese- und Schreibzugänge und die Rotation der API-Schlüssel (M2, M4)	teilweise
ASI04 Agentic Supply Chain	Ollama-Modelle, n8n-Community-Nodes, Docker-Images (jetzt auch das eigene Runner-Image mit Jimp), Testdaten von Hugging Face; Bestand mit Version erfassen (M9)	offen
ASI06 Memory & Context Poisoning	Trainingsdaten der Startstufe und kNN-Pool; geflaggte Fälle und quality -Fälle sind ausgeschlossen; offen sind ein Poisoning-Test und die Bereinigung der Testfälle im Pool	teilweise
ASI08 Cascading Failures	Kosten-DoS über die Eskalationsleiter; Limit je Beleg (M7); max_kosten und Budget-Prüfung sind umgesetzt, ein Limit nach Versuchszahl nicht	teilweise
ASI05, ASI07, ASI09, ASI10	keine Codeausführung durch Modelle, keine Agent-zu-Agent-Kommunikation, Freigabe über HITL; derzeit nicht relevant, bei Erweiterungen erneut prüfen	erfüllt

7.6.3 Schichtübergreifende Angriffskette (MAESTRO)

Das Framework MAESTRO der Cloud Security Alliance betrachtet ein agentisches System in sieben Schichten und sucht nach Ketten über Schichtgrenzen hinweg. Für SCORE ist folgende Kette maßgeblich: Ein manipulierter Beleg (Agenten-Ökosystem) wird fälschlich als „erfolgreich“ gespeichert (Datenebene), gelangt in die Trainingsdaten der Startstufe (Evaluation) und führt dazu, dass ähnliche Belege künftig auf einer zu schwachen Stufe starten. Unterbrochen wird die Kette durch den Ausschluss geflaggter Fälle aus allen Lerndaten und den Poisoning-Test.

7.6.4 Maßnahmenvorschläge

Nr.	Maßnahme	Bezug im Handout	Status
M1	Eskalationsgrenze nach Vertraulichkeit: Belege mit besonders schützenswertem Inhalt (z. B. Personal- oder Gesundheitsbezug) nutzen nur die lokalen Stufen 0 und 1; scheitern diese, wird der Beleg zum Klärfall statt in die Cloud zu eskalieren.	Lokales Modell statt Cloud: „Vertrauliches lokal, Unkritisches in der Cloud“	vorgeschlagen
M2	Lesen und Schreiben trennen: eigene Datenbankzugänge; Berichts-Workflows nur lesend, nur der Hauptprozess schreibend.	Konfigurationsregeln 2 und 3	vorgeschlagen
M3	SQL-API abschotten: Ports 5001 und 5005 nur im internen Docker-Netz erreichbar.	Isolation, Härtung Tool-Integration	erfüllt
M4	Zugänge kurz halten: API-Schlüssel nur in n8n-Credentials, mit Ablaufdatum und Rotation.	Konfigurationsregel 5	vorgeschlagen
M5	Ausgehende Verbindungen positiv listen: Container erreichen nur Gateway, OpenRouter, Anthropic und VIES.	Isolation: ausgehende Verbindungen nur nach Freigabeliste	vorgeschlagen

M6	Fail closed: Fehler oder Timeout in der Sicherheitsprüfung führen im Enforce-Modus zum Klärfall; eigener Unit-Test.	Sichere Entwicklung: Failsafe-Defaults	vorgeschlagen
M7	Limit je Beleg: nach n Versuchen oder x Euro Klärfall statt weiterer Eskalation.	Leistung & Umgehung: Rate Limits	teilweise (Euro-Limit über max_kosten)
M8	Mehrfachläufe im Red-Team-Test: jeder Angriffsbeleg 3- bis 5-mal; ein Durchbruch in einem Lauf ist ein Befund.	Sichere Entwicklung: ein Durchlauf je Testfall genügt nicht	vorgeschlagen
M9	Bestand der Komponenten: Modelle, Nodes und Images mit Anbieter, Version und verarbeiteten Daten erfassen.	Drittkomponenten, Startcheckliste	vorgeschlagen
M10	Flag-Rate als Frühwarnsignal: Verdachtsquote in der Metriken-Statistik; starker Anstieg oder Abfall auf null wird gemeldet.	Sicherer Betrieb: Leistungsabweichung als Warnsignal	vorgeschlagen
M11	Notschalter: zentraler Schalter, der alle Cloud-Stufen sperrt oder jeden Beleg in HITL leitet; Teil des Notfallplans.	Sicherer Betrieb: Notfallplan mit Abschaltmöglichkeit	vorgeschlagen
M12	Dienstleister absichern: Gateway, OpenRouter und Anthropic als Auftragsverarbeiter (AV-Vertrag nach Art. 28 DSGVO) und als Dienstleister nach § 62a StBerG (Verschwiegenheitsverpflichtung).	Regulatorik: DSGVO Art. 28	vorgeschlagen

7.6.5 Einordnung im Reifegradmodell

Im Reifegradmodell zur Integrität von Agenten (Proofpoint) entspricht der Shadow-Modus der Stufe 4 „Überwacht“ (Regeln im Beobachtungsmodus), das Umschalten auf Enforce der Stufe 5 „Durchgesetzt“ (Regeln greifen aktiv). Der Shadow-Modus ist damit ein bewusster Reifeschritt vor der Durchsetzung.

7.6.6 Startcheckliste als Freigabebitor

Die Startcheckliste des Handouts dient als formales Kriterium für die anstehende Freigabe des Enforce-Modus. Die LightGBM-Startstufe ist bereits produktiv; für sie dient die Liste als nachträgliche Prüfung.

Kriterium	Stand in SCORE	Status
Anwendungsfall schriftlich beschrieben, mit Zweck und Grenzen	Projektantrag und Anforderungsdokument	erfüllt
Zulässiges Verhalten festgehalten, nicht nur Erlaubtes	festes JSON-Schema, Belegart-Katalog, Prüfregeln der Ergebnisprüfung	erfüllt
Mindestens ein Kontrollpunkt vor jeder Außenwirkung	Ergebnis ist ein Vorschlag; Klärfälle über HITL	erfüllt
Eigenes Konto mit zugeschnittenen Rechten	SQL-API abgeschottet (M3); Trennung von Lesen und Schreiben ausstehend (M2)	teilweise
Alle angebundenen Erweiterungen erfasst	Module bekannt, Versionen und Daten noch nicht erfasst (M9)	teilweise
Risikobewertung dokumentiert und nicht rot	Risiken im Projektantrag, OWASP-Zuordnung in 7.6.2; offene Punkte bei ASI01, ASI03, ASI04 und ASI06	teilweise
Protokollierung aktiv, Person namentlich für die Sichtung benannt	Befunde in <code>daten_json.sicherheits</code> , Audit-Log und Berichten; verantwortliche Person noch zu benennen	teilweise
Werkzeug läuft unternehmensverwaltet	für den späteren Betrieb festzulegen	offen

Datenschutz und bei Bedarf Betriebsrat eingebunden	für den späteren Betrieb festzulegen (M12)	offen
Notfallplan erarbeitet und abgestimmt	Notschalter vorgeschlagen (M11), Plan ausstehend	offen

8. Fazit und Empfehlung

Fazit: SCORE hat gezeigt, dass eine lernende Verfahrenswahl die beiden größten Kostenblöcke der Belegverarbeitung zugleich senkt: Die Erkennungskosten fallen auf rund 1 % des heutigen IDP-/OCR-Preises, und weniger Klärfälle binden weniger Personal. Mit der Belegart-Architektur erfasst SCORE je Beleg die passenden Felder und prüft Summen und, wo vorgesehen, die USt-IdNr. Der Massentest mit 1000 Belegen belegt Stabilität (kein Beleg ohne Ergebnis), Kosten (1,07 € je 1000 Belege) und Durchsatz für den Normalbetrieb. Offen ist die Richtigkeit der Felder auf echten, deutschen Belegen: Auf den Testkassenbons lag sie je Feld zwischen 41 und 71 %, und die Sicherheitsprüfung markiert im Beobachtungsmodus viele Belege. Beides muss der Pilot klären, bevor SCORE den bisherigen Dienst ablöst und der Enforce-Modus eingeschaltet wird.

Empfehlung an die Kanzleileitung:

1. **Pilot freigeben** (4 Wochen, Start ab KW 43): SCORE verarbeitet die Belege einer Mandantengruppe mit gemischten Belegtypen parallel zum bisherigen Dienst. Gemessen werden Dunkelverarbeitung, Feldrichtigkeit an einer manuell geprüften Stichprobe, Zeit je Klärfall per Stoppuhr, Durchsatz und Kosten. Vorher: Testfälle aus dem Trainingspool nehmen oder kennzeichnen, Verschwiegenheitsverpflichtung der Cloud-Anbieter (§ 62a StBerG) einholen.
2. **Hardware beschaffen:** ein Mac Studio mit M5 Ultra inklusive USV für den Pilot. Für den Produktivbetrieb kommt ein zweites Gerät hinzu, vorwiegend als Failover, damit die Belegverarbeitung bei einem Ausfall weiterläuft, und zusätzlich zur Lastverteilung bei Spitzenlast, etwa zum Monatsende.
3. **Rollen festlegen:** technischer Betrieb, eine benannte Fachkraft für die Klärfälle mit Vertretung, Eskalation an die Kanzleileitung.
4. **Nach erfolgreichem Pilot:** Sicherheitsprüfung kalibrieren und von „beobachten“ auf „durchsetzen“ umstellen, Rechenprüfung vom Shadow-Modus in die Ergebnisentscheidung übernehmen, weitere Mandantengruppen anbinden und den bisherigen IDP-/OCR-Dienst kündigen.

Offene Punkte, die der Pilot klären muss:

- **Feldrichtigkeit:** Die Quote ohne Klärfall (93,4 %) ist kein Maß für Richtigkeit. Eine geprüfte Stichprobe deutscher Belege zeigt die echte Fehlerquote.
- **Zeit je Klärfall:** Die 1,2 Minuten sind angenommen; bei 2 Minuten sind es 1,0 statt 0,62 Vollzeitkräfte.
- **Spitzenlast:** Der Normalbetrieb (119 Belege/Std.) ist mit 170 bis 190 je Stunde auf dem Testrechner gedeckt; das Monatsvolumen in 12 Stunden (2.500/Std.) schafft SCORE nicht, dafür ist Parallelisierung nötig.
- **Nutzen der lernenden Startstufe:** Auf den bisherigen Testbelegen lag die Regel „immer Stufe 2“ gleichauf; den Vorteil muss eine Mischung mit vielen einfachen Belegen belegen.
- **Lokaler Anteil:** Heute gehen je nach Beleg-Mix zwei Drittel bis 86 % der Belege an eine Cloud-Stufe; ob große Open-Weight-Modelle sie ersetzen können, zeigt ein Proof of Concept.

8.1 Technische Grenzen und offene Punkte

- **Sicherheit:** Der Detektor ist nur auf sauberen, gerenderten Scans mit 300 dpi getestet; Handyfotos, zerknittertes Papier und starke JPEG-Kompression stehen aus. Versteckter Text direkt an sichtbarem Text (innerhalb von 8 px) oder über Tabellenlinien wird nicht erkannt; rein weißer Text auf Weiß ist grundsätzlich nicht erkennbar, aber auch für ein Vision-Modell nicht lesbar. Die Red-Team-Belege sind

synthetisch. Offen sind die Shadow-Kalibrierung anhand der Massentest-Befunde (Verdachtsquoten bis 83 % je Belegart), Poisoning-Test, Mehrfachläufe je Red-Team-Beleg, Fail closed bei Fehlern der Sicherheitsprüfung und das Umschalten auf Enforce.

- **Feld-Erkennung:** Platzhalter wie „nicht vorhanden“ als nicht erkannt werten; Klassifikator v2 auf dem vollen Massentest erneut messen; Tesseract-Dienst um einen `psm`-Parameter erweitern (Seitenanalyse 6 für Belege).
- **Startstufe und Lernbasis:** Massentestfälle aus dem Trainingspool nehmen oder kennzeichnen; Poisoning-Test; den LightGBM-Aufruf bei `quality` überspringen; kNN zusätzlich mit Regel `min_tier` vergleichen; Wirkung der Priorität `zeit` im Live-Betrieb messen.
- **Strategie quality:** Rangfolge aus einer View statt fest in der Registry, Zweitbestätigung durch ein Modell einer anderen Familie.
- **Laufzeit:** Messungen stammen von einem CPU-Rechner; Werte für den Mac Studio sind zu messen. Docling nur mit OCR bei fehlender Textebene und begrenzter Gleichzeitigkeit, Ollama auf einen gleichzeitigen Aufruf begrenzen, Bildanalyse auf eigenem Runner sind getestete oder vorgemerkte Hebel. Die Knotenzeiten decken wegen der Bereinigung der n8n-Datenbank nur 732 der 1000 Belege ab; während des Laufs wurden zudem die Task-Runner umgebaut, was Einzelzeiten beeinflusst haben kann.
- **VIES und Rechenprüfung:** VIES-Abfragen unter Last und die Fehlalarmrate der Rechenprüfung auf deutschen Belegen sind noch nicht gemessen; die Rechenprüfung läuft deshalb im Shadow-Modus.
- **Altbestand:** Einzelne ältere Workflows (Gewichte-Berechnung, stillgelegt; kNN-Validierung; frühere Massentest-Workflows) sind noch vorhanden und werden vor dem Pilot aufgeräumt.